นโยบายความปลอดภัยและการคุ้มครองข้อมูลส่วนบุคคล (PDPA)

ระบบประเมินผลการปฏิบัติงาน SML PMS — ฉบับร่างสำหรับพิจารณา (ควรให้ DPO/ฝ่ายกฎหมายตรวจก่อนประกาศใช้)

1. วัตถุประสงค์และขอบเขต

ระบบ SML PMS เก็บและใช้ข้อมูลส่วนบุคคลของพนักงานตาม พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 (PDPA) นโยบายนี้ใช้กับพนักงาน หัวหน้างาน ผู้ประเมิน ผู้บริหาร และ HR/Admin ทุกคนที่ใช้งานระบบ

2. ข้อมูลที่เก็บและวัตถุประสงค์

ข้อมูล	วัตถุประสงค์
ชื่อ รหัสพนักงาน ตำแหน่ง สังกัด สายบังคับบัญชา อีเมล LINE User ID	ยืนยันตัวตน กำหนดสิทธิ์ แจ้งเตือน
ผลประเมิน คะแนน ความเห็นผู้ประเมิน เกรด KPI แผนพัฒนา (IDP)	ประเมินผลงาน พิจารณาค่าตอบแทน/พัฒนาบุคลากร
ข้อมูลเวลาทำงาน การลา มาสาย ใบเตือน/หมายเหตุวินัย	คำนวณคะแนนเวลาทำงานตามระเบียบบริษัท
PIN (เก็บเป็นค่าแฮชเท่านั้น) บันทึกการเข้าใช้งาน (Audit Log)	รักษาความปลอดภัยและตรวจสอบย้อนหลัง

ฐานทางกฎหมาย: การปฏิบัติตามสัญญาจ้าง และประโยชน์โดยชอบด้วยกฎหมายของบริษัทในการบริหารงานบุคคล ข้อมูลอ่อนไหว (เช่น สุขภาพจากใบรับรองแพทย์) เก็บเท่าที่จำเป็นและจำกัดผู้เข้าถึง

3. หน้าที่ของผู้ใช้งานทุกคน

- **ห้ามบอก PIN แก่ผู้อื่น** ไม่ว่าจะเป็นเพื่อนร่วมงาน หัวหน้า หรือ HR (HR จะไม่ขอ PIN จากท่านทางใดทั้งสิ้น)
- **ห้ามให้ผู้อื่นยืมบัญชี** หรือล็อกอินค้างไว้ให้ผู้อื่นดู/ใช้งานแทน
- ห้ามจดหรือบันทึก PIN ในที่เปิดเผย ห้ามใช้ PIN ที่เดาง่าย (เช่น 1234, วันเกิด)
- ออกจากระบบทุกครั้งเมื่อใช้เครื่องสาธารณะ/เครื่องร่วม

- ห้ามถ่ายภาพ คัดลอก ส่งต่อ หรือเปิดเผยผลประเมิน/ข้อมูลของผู้อื่น เว้นแต่ได้รับมอบหมายตามหน้าที่
- ผู้ประเมินใช้ข้อมูลของลูกทีมเพื่อการประเมินเท่านั้น และเก็บเป็นความลับ
- หากสงสัยว่า PIN รั่วไหลหรือมีผู้อื่นเข้าบัญชี ให้ **เปลี่ยน PIN ทันที** ("ลืม PIN?") และแจ้ง HR ภายใน 24 ชั่วโมง

การให้ PIN แก่ผู้อื่นเป็นการให้ผู้อื่นเข้าถึงข้อมูลส่วนบุคคลของท่านและของผู้อื่นโดยไม่ได้รับอนุญาต ผู้เข้าถึงโดยไม่มีสิทธิ์อาจมีความผิดตามกฎหมาย (เช่น พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์) และเข้าข่ายผิดวินัยตามข้อบังคับเกี่ยวกับการทำงาน — ผู้ให้ใช้บัญชีต้องรับผิดชอบการกระทำที่เกิดขึ้นภายใต้บัญชีของตน

4. มาตรการรักษาความปลอดภัยของบริษัท

- PIN เก็บเป็นแฮช ไม่สามารถดูย้อนหลังได้; Admin ไม่เห็น PIN จริงของพนักงาน
- ล็อกบัญชีชั่วคราวเมื่อใส่ PIN ผิดซ้ำ; บัตรผ่านเข้าระบบหมดอายุอัตโนมัติ
- แยกสิทธิ์ตามบทบาท: พนักงานเห็นเฉพาะผลของตนเอง หัวหน้าเห็นเฉพาะสายบังคับบัญชา
- เกรดและขั้นตอนภายใน (Calibration) ไม่แสดงให้พนักงานจนกว่าอนุมัติขั้นสุดท้าย
- บันทึกการเข้าใช้งานและการแก้ไขสำคัญ (Audit Log) เพื่อตรวจสอบย้อนหลัง
- การเชื่อมต่อฐานข้อมูลผ่านเซิร์ฟเวอร์กลางด้วยสิทธิ์จำกัดเฉพาะไซต์ที่กำหนด
- จำกัดผู้ดูแลระบบ (Admin/HR) ให้น้อยที่สุดและทบทวนสิทธิ์เป็นระยะ

5. สิทธิของเจ้าของข้อมูล

พนักงานมีสิทธิขอเข้าถึง ขอสำเนา แก้ไขข้อมูลให้ถูกต้อง คัดค้าน หรือขอให้ลบ/ระงับการใช้ข้อมูลตามที่ PDPA กำหนด (ยกเว้นข้อมูลที่บริษัทมีหน้าที่ต้องเก็บตามกฎหมาย) โดยติดต่อ HR/DPO ของบริษัท บริษัทจะตอบภายใน 30 วัน

6. ระยะเวลาเก็บและการลบข้อมูล

เก็บผลประเมินตามระยะเวลาที่ระเบียบบริษัทกำหนด (เสนอ: ไม่เกิน ___ ปี หลังสิ้นสุดการเป็นพนักงาน) เมื่อพ้นกำหนดจะลบหรือทำให้ไม่สามารถระบุตัวตนได้ ข้อมูลทดสอบ/ข้อมูลเก่าที่ไม่จำเป็นต้องล้างตามรอบ

7. เหตุละเมิดข้อมูล

- ผู้พบเหตุแจ้ง HR/DPO ทันที
- บริษัทประเมินผลกระทบ และหากมีความเสี่ยงต่อสิทธิเสรีภาพของบุคคล จะแจ้งสำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล (สคส.) ภายใน 72 ชั่วโมงนับแต่

ทราบเหตุ และแจ้งเจ้าของข้อมูลหากมีความเสี่ยงสูง
- เปลี่ยน PIN/ระงับบัญชีที่เกี่ยวข้อง และตรวจ Audit Log

8. ผลของการฝ่าฝืน

การฝ่าฝืนนโยบายนี้ (เช่น ให้ผู้อื่นใช้ PIN เปิดเผยผลประเมินของผู้อื่น) อาจถูกพิจารณาทางวินัยตามข้อบังคับเกี่ยวกับการทำงาน (บริษัทต้องระบุเรื่องนี้ไว้ในข้อบังคับ/ประกาศล่วงหน้าจึงจะลงโทษได้) และอาจมีความรับผิดทางกฎหมายอื่น

การรับทราบ
ข้าพเจ้าได้อ่านและเข้าใจนโยบายนี้ และจะปฏิบัติตามอย่างเคร่งครัด

ชื่อ-สกุล _____ รหัสพนักงาน _____ ลงชื่อ _____ วันที่ ____/____/____